

Individual Assessment Coversheet

To be attached to the front of the assessment.

Campus: Tyger Valley

Faculty: Information Technology

Module Code: ITSSA2-22

Group: 1

Lecturer's Name: Vusumuzi Moyo

Student Full Name: Keenan Paiva Batista

Student Number: 4845350

Indicate	Yes	No
Plagiarism report attached		

Declaration:

I declare that this assessment is my own original work except for source material explicitly acknowledged. I also declare that this assessment or any other of my original work related to it has not been previously, or is not being simultaneously, submitted for this or any other course. I am aware of the AI policy and acknowledge that I have not used any AI technology to generate or manipulate data, other than as permitted by the assessment instructions. I also declare that I am aware of the Institution's policy and regulations on honesty in academic work as set out in the Conditions of Enrolment, and of the disciplinary guidelines applicable to breaches of such policy and regulations.

Signature 	Date 13 June 2025
---	-----------------------------

Lecturer's Comments:

--

Marks Awarded:	%
-----------------------	----------

Signature	Date
------------------	-------------

Table of Contents

Section A

Question 1.....Page 1-3

Question 2.....Page 4-7

Question 3..... Page 8-10

Question 4.....Page 11-12

Bibliography..... Page 13

Section A

Question 1

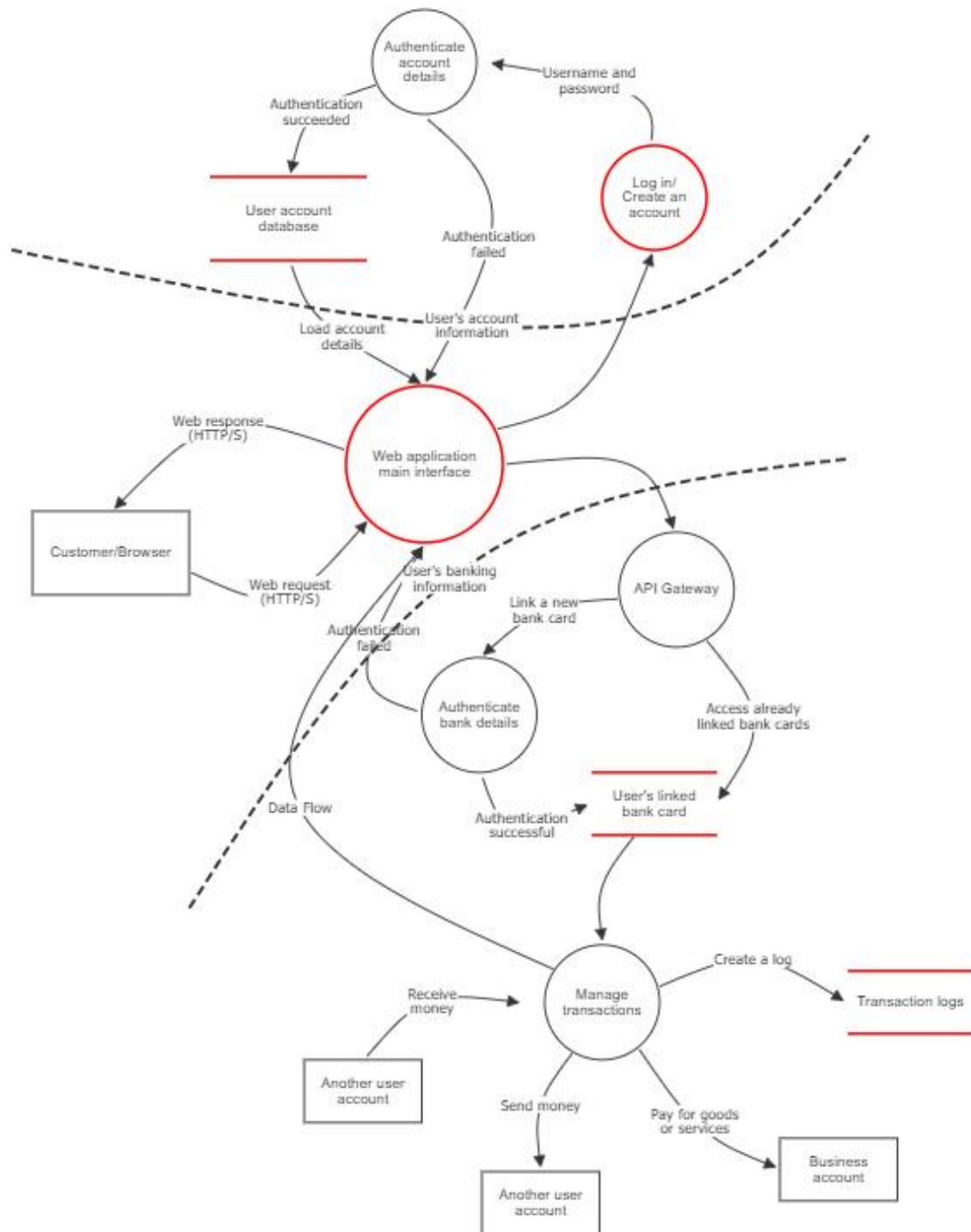


Figure 1: The initial StellarPay web application threat model

1a) Important assets that must be protected for a financial system such as the StellarPay Digital Banking system are the personal information of their customers like their banking and account details. Personal details of the user can be found within the user account database, as shown in figure 1, because the user has to create or log into a StellarPay account that stores sensitive information such as their full names, address and password. Moreover, the user will have to link their banking cards to their StellarPay account in order to manage transactions, which makes all the user's banking data associated with those bank cards vulnerable to potential attacks on the web application. This data should be considered assets that must be protected by StellarPay for various reasons such as staying compliant with regulations and creating a sense of trust among their customers in the application, which can lead to an increase in the adoption of the application with other customers while perceived risks can lead to a decrease in customers (Apau, Elzbieta, Lallie, 2025).

Furthermore, user transaction logs are also an asset that must be protected in StellarPay Digital Banking's system. Transaction logs refers to logs that are created every time a transaction occurs on the user's specific bank card, which enables the user to effectively manage their transactions. These logs are considered assets in the web application as they can be seen as valuable to attackers for various reasons such as making their attack on the system harder to identify by deleting suspicious transactions before users can detect them. The longer that attackers can remain undetected, the potential severity of an attack can increase if StellarPay Digital Banking detects the breach late.

1b) The main entry point for users to gain access to StellarPay's web application is through a browser. When the user enters the web application through the browser, they will then have to create or log into an already existing StellarPay account in order to utilise the services offered by the web application. Moreover, another potential entry point into the web application exists when the user receives money from an outside user as shown in figure 1. This potential entry point could be used by attackers to immediately gain access to the users banking information on the web application if there are security vulnerabilities that are detected here.

In addition, there are two trust boundaries that can be identified within StellarPay's web application is when the user creates or log into a StellarPay account as well as when the user links their bank cards to the application in order to conduct transactions. The account creation and login screen will require users to provide appropriate inputs to effectively create an account or meet the required authentication to prove to the web application that they are authorized to access that account. Additionally, after gaining access to the account, further security measures are introduced at the API gateway, as shown in figure 1, where the user has to provide further authentication details to ensure that any new bank cards and banking information that are linked to the StellarPay account are done by the legitimate user.

Furthermore, data flows can be seen between each process, as shown in figure 1, where the main flow of data is when the user enters the web application, when an account is created or logged into and when transactions are conducted on the linked bank cards. Users log into the web application through a browser and will have to successfully create an account or provide the correct authentication details to gain access to their account. The user will then have the option to use bank cards that they have already linked to the account and perform transactions with those cards as well as link new banks cards after validating the required bank authentication details.

1c) As shown in figure 1, each process has purpose in the web application for aspects like security and the logical flow of data. When the user enters the web application through their browser, they have to create or log into a StellarPay account that provides certain security advantages. The main benefit of this is the differentiation of each user in the web application where each account

will have its own authentication details that prevents attackers from gaining access to multiple user accounts. If the user attempts to log into their account, the system will determine if the authentication details provided by the user are correct before they can access the account, which makes this mechanism enforce authorisation and authentication in the application.

Furthermore, the web application will create an API gateway to enable communication between the application itself and various financial institutions that enables users to link their bank cards to the application. When linking their bank cards, users will have to prove that they are the legitimate user of the bank card by providing authentication details that must match with the data stored by the financial institution that the card belongs to.

Question 2

Web application main interface (Process)

Description:

Number	Title	Type	Priority	Status	Score	Description	Mitigations
14	Web application overloaded	Denial of service	High	Open	8	Attackers can overload the web application to prevent users from accessing their StellarPay's accounts from their browser.	Implement load balancing to minimise the impact of DDoS attacks.

Figure 2.1: Main interface details

Log in/ Create an account (Process)

Description:

Number	Title	Type	Priority	Status	Score	Description	Mitigations
9	Impersonating legitimate users	Spoofing	High	Open	8	Authentication details can be stolen by attackers and used to impersonate legitimate users in StellarPay's web application.	Conduct user training, implement a black list to prevent SQL queries and an intrusion detection system to detect suspicious behaviour.
18	Steal session data	Elevation of privilege	Medium	Open	6	Steal an employee's session data in order to gain additional user privileges.	Implement an XSS checker to prevent attackers from stealing session data by injection malicious script.

Figure 2.2: Account creation and login interface details

User account database (Store)

Description:

Number	Title	Type	Priority	Status	Score	Description	Mitigations
10	Altering a user's authentication details	Tampering	Medium	Open	6	A user's authentication details could be altered by attackers to make it difficult for the user to re-gain access to their StellarPay account.	Implement a black list to prevent SQL queries from being executed from the account creation and log in component.

Figure 2.3: User account database details

User's linked bank card (Store)

Description:

Number	Title	Type	Priority	Status	Score	Description	Mitigations
12	User's personal and banking information revealed	Information disclosure	Critical	Open	9	The user's sensitive data such as personal and banking information can be stolen and revealed to other attackers by the initial attackers.	Implement an intrusion detection system to detect suspicious behaviour.

Figure 2.4: Linked bank card details

Transaction logs (Store)

Description:

Number	Title	Type	Priority	Status	Score	Description	Mitigations
11	Removing transaction logs	Repudiation	Medium	Open	5	User transaction logs that are created by attackers can be erased or altered.	Implement an intrusion detection system to detect suspicious behaviour.

Figure 2.5: Transaction log details

2a) As shown from figures 2.1 to 2.5, there are various potential threats that can compromise StellarPay's web application, and these threats can be categorised under the components of STRIDE:

- Spoofing:
 - The authentication details of a user can be stolen by attackers through various methods, such as using social engineering to get the user to reveal their authentication details, and can then be used to impersonate the user in StellarPay's web application and perform certain actions.
- Tampering:
 - A user's authentication details could be altered by attackers who have access to their account to make it difficult for the targeted user to re-gain access and control over their StellarPay account from the attackers.
- Repudiation:
 - User transaction logs that are created by the attackers can be erased or altered to keep their attack hidden from the targeted user and StellarPay.
- Information disclosure:
 - The user's sensitive data such as personal and banking information can be stolen and revealed to other attackers by the initial attackers if they are able to access the specific user's account.
- Denial of service:
 - Attackers can overload the web application to prevent users from accessing their StellarPay's accounts from their browser, which interrupts both StellarPay's and the user's operations that are done over this web application.
- Elevation of privilege:
 - Attackers could gain administrator privileges in the web application and can then perform many destructive actions that can't be done without these privileges, like viewing the authentication details of multiple users.

2b) As shown from figures 2.1 to 2.5, various components within StellarPay's web application are impacted by the STRIDE threats that were identified. These impacted web components, that can be found in figure 1, consist of:

- Web application main interface component
 - This component is the main interface of the web application that enables users to perform actions such as creating a StellarPay account or logging into one as well as linking bank cards and managing transaction related to the specific bank card. Therefore, this component is likely to have denial of service threats through overloading the application, because this type of threat will prevent users from accessing every other component in this application.
- The login/create an account component
 - This component is an interface that enables users to create or log into an already existing StellarPay account that determines their user privileges in the web application. Therefore, elevation of privilege threats can occur through this component, because attackers could alter these user privileges in a manner that allows them to perform actions on all components in the application. In addition, this component can also have spoofing threats where the attackers can impersonate a specific user if they are able to obtain that user's authentication details.
- User account database component
 - This component stores all the data related to StellarPay user accounts. Therefore, this component is susceptible to tamper threats, because attackers would want to

tamper with the user's account information such as their authentication details to lock them out of their account and enable the attackers to further compromise their targeted user.

- User's linked bank card component
 - This component contains all bank cards that the user has linked to their StellarPay account to manage and conduct transactions. Therefore, this component is vulnerable to information disclosure threats where attackers can reveal the user's sensitive personal and banking information associated with the linked bank cards to other cybercriminals, allowing them to further compromise the user after the initial breach.
- Transaction logs component
 - This component logs all transactions performed by the user that allows them to effectively manage their finances. Therefore, this component is vulnerable to repudiation threats if attackers are able to alter these logs, because altering or removing these logs enables attackers to hide their attack within the web application from StellarPay and the user if the attack involves performing transactions from the user's account.

2c) As shown from figures 2.1 to 2.5, each threat has a specified threat score and priority that takes into consideration the impact on financial transactions and the likelihood of exploitation:

- Spoofing threat:
 - This threat has a high priority, because the attackers only require the authentication details of the user to get access to their account. If they get access to the account, they will then be able to perform any action that the legitimate user can perform, which can lead to other threats occurring such as viewing and tampering the user's financial information.
- Tampering threat:
 - This threat has a medium priority, because attackers in most circumstances will have to first gain access to the account in order to tamper with the user's authentication details. Altering these details can temporarily prevent users from getting into their account and perform financial operations.
- Repudiation threat:
 - This threat has a medium priority, because attackers have to first gain access to the user's account as well as bypass any additional security that is implemented to protect the transaction logs. Altering these transaction logs can hinder the financial operations for the user if it is performed with the purpose of disrupting the user by removing important logs. These logs can also be removed to hide the attackers from the users.
- Information disclosure threat:
 - This threat has a critical priority, because attackers have to first gain access to the user's account. Revealing this information will be extremely destructive for the user's financial operations due to other attackers using this information to perform their own attacks on the user.
- Denial of service threat:
 - This threat has a high priority, because attackers can prevent users from accessing the web application through various methods such as overloading the application with requests. Preventing users from accessing the web application completely interrupts their financial operations.

- Elevation of privilege threat:
 - This threat has a medium priority, because attackers have to get the authentication details of users that work for StellarPay who will have different user privileges. With elevated privileges, attackers can perform actions that are only possible with these privileges such as accessing all user account information in the database. Actions like these can result in further attacks being made on the system that can impact the financial operations of users.

Question 3

3a) As shown from figures 2.1 to 2.5, each threat can have multiple vulnerabilities that could be used by attackers to perform attacks on the web application. These vulnerabilities include:

- Spoofing vulnerabilities:
 - Social engineering can be utilised by attackers to persuade and trick users into granting them access to their StellarPay account by providing them their authentication details (Campbell, 2019). This enables the attackers to easily gain access to the targeted user's account through the account login function of the web application, if the user is convinced by the attackers.
 - Additionally, an attacker can perform SQL injections on the account creation and login component of the web application to retrieve the authentication details of the user by running malicious SQL queries that can be recognised by the user account database (Sarika *et al.*, 2018).
- Tampering vulnerabilities:
 - Attackers can tamper with the user's account information by gaining access to their account through any successful spoofing attack.
 - In addition, successful SQL injections can also be used to tamper with a user's account information stored in the user account database from the account creation and login interface.
- Repudiation vulnerabilities:
 - Successful spoofing attacks can enable attackers to access all the user's bank cards that are already linked to their account, which will allow them to alter the specific card's transaction logs if no additional security measures are in place.
- Information disclosure vulnerabilities:
 - Successful spoofing attacks can enable attackers to access all the user's bank cards that are already linked to their account and view the sensitive information associated with the cards. This sensitive information can then be disclosed to other users and cybercriminals.
- Denial of service vulnerabilities:
 - A successful tampering attack that changes the user's authentication details can also be considered a denial-of-service attack, because it temporally prevents the user from accessing the StellarPay account.
 - However, the main denial of service vulnerability in the web application is its inability to handle large amounts of requests, which will overload the web application and prevent all users from accessing the web application. This can be accomplished by attackers performing a DDoS attack where a combination of multiple computers is used as an attack platform to flood the web application with requests (Li *et al.*, 2019).
- Elevation of privilege vulnerabilities:
 - Attackers can also perform a stored cross-site scripting (XSS) attack on the web application by injecting malicious script into the account creation and login interface that steals user data and hijack the session information of a StellarPay employee (Hu, Zhang and Yang, 2025). They can then use this data to impersonate the employee and make use of their account privileges to perform advanced attacks.

3b) The vulnerabilities of each identified threat can be mitigated in the web application with various measures that enhance the application's security. The mitigation measures for each vulnerability include:

- Social engineering
 - The likelihood of a social engineering attack can be reduced by StellarPay by improving the security awareness of all users that utilise the web application (Li, Song and Pang, 2023). This mitigation can be accomplished by conducting user training sessions for all users that educate them on the possibility of software engineering attacks as well as how they can identify and report it. Additionally, an intrusion detection system can be implemented into the web application to monitor detect suspicious behaviour like security violations that could indicate that an attacker has gained access to a user's account, enabling StellarPay to act and prevent damage (Li, 2025).
- SQL injections
 - The user account database is already established in the web application, which prevents StellarPay from removing the SQL interpreter due to how costly and risky it would be to make a change like this. Moreover, a white list can't be used, because the input required from the user can't be predefined and must be dynamic. Therefore, a black list should be utilised where the application automatically blocks known terms and characters that are used when executing SQL commands during injection attacks (Kakisim, 2024). Furthermore, this black list must constantly be updated to ensure that new SQL injection attacks that are discovered are blocked.
- Stored cross-site scripting (XSS) injections
 - An XSS checker, similar to a black list, can be implemented to detect and block any unauthorised characters on both the client and server side of the web application (Gupta, 2015). This XSS checker, like a black list, can also be continuously updated to ensure that new XSS threats that are discovered will be blocked by the checker.
- DDoS attacks
 - Load balancing can be implemented in order to optimise the web application's resources to handle the large number of requests from DDoS attacks and minimise its impact on the web application (Gavric, Shalaginov, Andrushevich, Rumsch, Paice, 2025).

3c) Each mitigation that was mentioned has its own strengths, trade-offs and limitations for the web application.

- User training
 - Training users to identify and avoid traps that are created by attackers can greatly reduce the likelihood of attacks on the web application due to user manipulation and mistakes. A potential trade-off for this mitigation strategy is that users will have to spend their time in order to be educated by StellarPay on security. However, users that don't work for StellarPay are less likely to join these training sessions than the employees of StellarPay, because they have no obligation to join these sessions and the impact of user training will then be minimal. The effectiveness of user training can be quite effective against threats under the condition that the users decide to join these sessions.
- Intrusion detection system

- Any suspicious activity that occurs within any component in the web application can be detected by the intrusion detection system and reported to StellarPay, which enables them to act against potential attackers. A trade-off for this mitigation is a reduction in the application's performance, since this mechanism constantly checks for suspicious behaviour. New categories of attacks can be performed on the application and remain undetected by this mechanism if StellarPay does not define this new suspicious behaviour in this mechanism.
- SQL black list
 - This mitigation can be used to protect against multiple attacks associated with the user account database such as spoofing, tampering and information disclosure attacks, which can be performed with SQL injections. A trade-off for this mitigation is that the password in user accounts can't include the symbols and characters that are blocked by the black list, which can make these passwords weaker in general than other systems that allow additional symbols and characters. The security that the black list provides is limited to only block queries that contain the characters that are defined in the black list.
- XSS checker
 - This mitigation is very similar to the SQL black list where multiple attacks that can be performed with an XSS attack can be prevented with an XSS checker. This mitigation can have a performance trade-off due to the checker constantly checking the application for unauthorised characters. Similar to the SQL black list, the XSS checker will only check for unauthorised characters that are defined by StellarPay, which means new XSS attacks could bypass the checker.
- Load balancing
 - This mitigation can greatly improve the overall performance of the web application than the application is currently. However, a trade-off for this mitigation is that it can be quite difficult and costly to implement into the application. Furthermore, introducing load balancing with a load balancer can have the limitation that it acts as a single point of failure in the application that should be protected by StellarPay.

Question 4

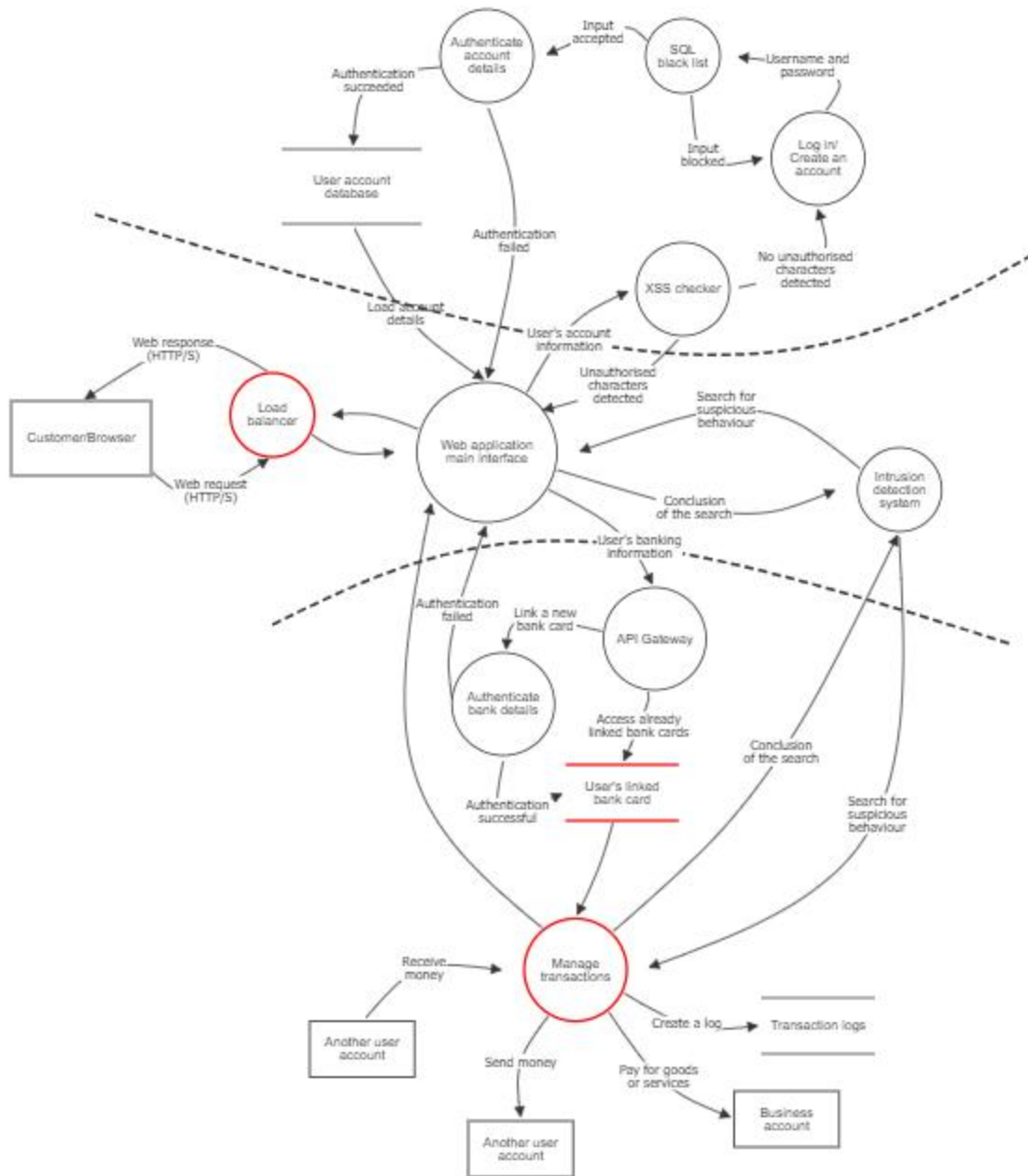


Figure 3: Refined StellarPay web application threat model

As shown in figure 3, the proposed mitigation strategies have been implemented to the web application to mitigate the vulnerabilities that were identified. A load balancer has been implemented to the web application where it manages the user's requests before it reaches the application itself. Managing these user requests in an efficient manner can improve the overall

performance of the web application for legitimate users while also minimising or preventing DDoS attacks on the application. In addition, when the user wants to create or log into their StellarPay account, an XSS checker and SQL black list has been implemented to prevent attackers from performing SQL and script injection attacks. The XSS checker is implemented in a manner that prevents malicious scripts from being injected into the account creation and login component by detecting unauthorised characters. The SQL black list will determine if the user input can be considered valid or not by determining if the input has characters that are blocked by the black list. Moreover, an intrusion detection system is implemented into the web application where it searches for suspicious behaviour in the main interface of the web application as well as the interface where users manage their transactions.

However, there are other risks that can still be identified within this new refined model. The load balancer, despite minimising the impact of DDoS attacks, acts as a potential single point of failure where an attacker can prevent users from accessing the web application if they are able to disrupt the load balancer itself. Despite the fact that it is more difficult for attackers to breach a user's account in the refined application than the initial version of the application, if an attacker is able to gain access to their account, they will be able to easily access the user's linked bank card due to there being no additional security features other than the intrusion detection system. Additionally, the refined application also does not protect against attacks like man in the middle attacks, since there is no data encryption when transactions are performed and users log in to their StellarPay account.

Bibliography

Apau, R., Elzbieta, T. & Lallie, H.S. (2025), "Towards a Better Understanding of Mobile Banking App Adoption and Use: Integrating Security, Risk, and Trust into UTAUT2", *Computers*, vol. 14, no. 4, pp. 144. [Online] Available at ProQuest

Campbell, C.C. 2019, "Solutions for counteracting human deception in social engineering attacks", *Information Technology & People*, vol. 32, no. 5, pp. 1130-1152. [Online] Available at ProQuest

Gavric, N., Shalaginov, A., Andrushevich, A., Rumsch, A. & Paice, A. (2025), "Enhancing Security in International Data Spaces: A STRIDE Framework Approach", *Technologies*, vol. 13, no. 1, pp. 8. [Online] Available at ProQuest

Gupta, N. (2015) 'XSS Defense: An Approach for Detecting and Preventing Cross Site Scripting Attacks', *Compusoft*, 4(3), pp. 1564–1571. [Online] Available at ProQuest

Hu, Z., Zhang, J. and Yang, H. (2025) 'XSS Attack Detection Based on Multisource Semantic Feature Fusion', *Electronics*, 14(6), p. 1174. [Online] Available at ProQuest

Kakisim, A.G. (2024) 'A deep learning approach based on multi-view consensus for SQL injection detection', *International Journal of Information Security*, 23(2), pp. 1541–1556. [Online] Available at ProQuest

Li, J. (2025) 'Deep Learning Models in Network Intrusion Detection Systems', *Applied Mathematics and Nonlinear Sciences*, 10(1). [Online] Available at ProQuest

Li, T., Song, C. and Pang, Q. (2023) 'Defending against social engineering attacks: A security pattern-based analysis framework', *International Studies of Economics*, 17(4), pp. 703–726. [Online] Available at ProQuest

Li, Y. *et al.* (2019) 'DDoS attack detection method based on feature extraction of deep belief network', *IOP Conference Series.Earth and Environmental Science*, 252(3). [Online] Available at ProQuest

Sarika *et al.* (2018) 'Framework for data security from SQL Injection in cloud computing', *International Journal of Advanced Research in Computer Science*, 9, pp. 257–262. [Online] Available at ProQuest